CLASE 2 · SEGUNDO ENCUENTRO

Ciberseguridad en la vida real

Amenazas, ataques y prevención

Fundamentos de Ciberseguridad · CFP20 – AMDELCO

Docente: Damian Trajster



PLAN DE CLASE · 120 MINUTOS

El recorrido de este encuentro

Repaso y presentación	10 min
Ingeniería social y phishing	20 min
Malware y copias de seguridad	15 min
Contraseñas, hashes y auditoría	25 min
Wi-Fi, HTTPS y actualizaciones	10 min
Ciberseguridad e inteligencia artificial	15 min
Seguridad laboral e incidentes	10 min
Caso institucional explicado	10 min
Síntesis y cierre	5 min

120 minutos de teoría con situaciones explicadas por el docente.

Repaso de la primera clase

TRÍADA CIA

¿Qué protege cada pilar?

Pensá en un ejemplo con el campus virtual.

CONCEPTOS

¿Amenaza, vulnerabilidad o riesgo?

¿Qué diferencia hay entre los tres conceptos?

WEB

¿Qué hace HTTPS y qué no hace?

Pensá en el candado del navegador.

OWASP

¿Para qué sirve el OWASP Top 10?

¿Quién lo usa y por qué?

Ingeniería social: manipular personas

Los atacantes manipulan a las personas para obtener información o provocar acciones. No atacan el sistema: atacan la **confianza**.

Urgencia	Autoridad	Confianza	Curiosidad	Miedo

Ejemplos cotidianos

- Un mensaje de “soporte” que pide tu contraseña
- Un falso sorteo que pide tus datos personales
- Alguien que pide entrar a una oficina siguiéndote

INGENIERÍA SOCIAL

Un correo bajo la lupa

Bandeja de entrada · correo de ejemplo

De: soporte@campus-seguro.example

Asunto: Tu cuenta será suspendida en 24 horas

Estimado usuario:

Detectamos actividad extraña. Verificá tus datos ahora o perderás el acceso.

Verificar mis datos

Enlace real: https://verifica-cuenta.example/login

Correo ficticio para practicar.

Lectura guiada del docente

Un mensaje amenaza con suspender una cuenta y pide verificar datos.

Revisamos quién lo envía, qué acción solicita y adónde dirige el enlace.

La verificación se hace desde el sitio oficial o por un canal conocido.

Ejemplo ficticio para explicar señales de phishing.

PHISHING

Qué señales conviene revisar

Remitente y dominio

Compará el dominio con el canal oficial de la organización.

Urgencia y presión

Un plazo breve puede buscar que decidas sin verificar.

Acción solicitada

Revisá pedidos de contraseñas, códigos o cambios de pago.

Destino real del enlace

Comprobá la dirección y entrá al servicio por una vía conocida.

El saludo personalizado y la buena redacción también pueden aparecer en un fraude.

AMENAZAS

Malware y sus efectos

Virus

Se replica al infectar archivos o programas que luego se ejecutan.

Troyano

Se presenta como una herramienta legítima y oculta una función maliciosa.

Spyware

Recopila información de la actividad o del dispositivo sin autorización.

Ransomware

Puede cifrar archivos y exigir un pago. Algunos ataques también roban datos.

Las categorías pueden superponerse. Varias pueden interrumpir una institución.

CONTINUIDAD

Ransomware y copias de seguridad

Impacto institucional

Los archivos dejan de estar disponibles.

Se interrumpen clases, trámites o servicios.

La filtración de datos puede sumar un daño adicional.

Copias para recuperar

Regla 3-2-1. Tres copias, dos tipos de soporte y una fuera del lugar.

Mantené una copia aislada o inmutable y verificá la restauración.

Las copias permiten recuperar datos. La prevención también requiere actualizaciones y controles de acceso.

PROTECCIÓN DE CUENTAS

Contraseñas largas y únicas

Largas y poco predecibles

La longitud ayuda cuando las palabras o caracteres se eligen con suficiente imprevisibilidad.

Una distinta por servicio

Una filtración tiene menos alcance si cada cuenta usa una clave diferente.

Gestor de contraseñas

Puede generar y almacenar claves únicas. Protegé su acceso y recuperación.

Ejemplos públicos

Las frases mostradas en clase sirven para explicar. Elegí una contraseña propia.

El tiempo de descubrimiento depende de la clave, el algoritmo y los recursos disponibles.

PROTECCIÓN DE CUENTAS

Segundo factor de autenticación

Algo que sabés

Una contraseña.

Algo que tenés

Un autenticador o una llave de seguridad.

Algo que sos

Una característica biométrica.

Más de un factor

MFA combina factores de categorías diferentes. Dos contraseñas pertenecen a la misma categoría.

Preferí opciones resistentes al phishing cuando estén disponibles, como llaves de seguridad o passkeys.

Cómo se almacena una contraseña

Registro

La aplicación deriva un hash usando la contraseña, un salt y parámetros de costo.

Almacenamiento

Guarda el hash junto con el salt y la configuración necesaria para verificarlo.

Verificación

Al iniciar sesión, calcula el valor correspondiente y lo compara con el guardado.

Un diseño correcto

Usa una función diseñada para contraseñas, como Argon2id. Un salt aleatorio único por registro dificulta reutilizar cálculos y tablas precalculadas.

Cuatro formas de comprometer una cuenta

Fuerza bruta

Explora sistemáticamente combinaciones dentro de un espacio definido.

Diccionario

Prueba candidatas de una lista, a veces con reglas de transformación.

Credenciales reutilizadas

Prueba pares de usuario y clave filtrados en otros servicios.

Phishing

Engaña a una persona para que entregue sus credenciales o autorice una acción.

Cada mecanismo requiere defensas acordes al punto que intenta aprovechar.

Auditoría con John the Ripper

Qué permite observar

John the Ripper prueba candidatas frente a hashes y detecta coincidencias.

Una auditoría registra qué contraseñas se encontraron y bajo qué condiciones.

Cómo interpretar el resultado

Encontrar una clave indica debilidad frente a las pruebas realizadas.

El resultado depende del formato, la configuración, el equipo y las candidatas probadas.

El video de clase ilustra la comparación con datos ficticios. Las auditorías requieren autorización.

Intentos en línea y fuera de línea

Intentos contra el login

Las solicitudes pasan por el servicio.

El sistema puede aplicar límites de intentos, alertas y MFA.

La aplicación participa en cada intento.

Comparaciones fuera de línea

La persona ya tiene una copia de los hashes.

Puede comparar candidatas en su propio equipo.

El costo del hash y la fortaleza de la clave condicionan cada prueba.

El límite del login no frena el cálculo local. MFA agrega protección al acceso posterior a la cuenta.

CONEXIONES Y DISPOSITIVOS

Wi-Fi y redes desconocidas

Qué aporta HTTPS

Cifra la comunicación entre el navegador y el sitio cuando se valida correctamente el certificado.

Esa protección también actúa al usar una red pública.

Qué revisar en una red ajena

Confirmá el nombre de la red y desactivá la conexión automática.

Evitá compartir archivos y atender pedidos inesperados de instalación o de credenciales.

Una red falsa o una página engañosa pueden inducir acciones peligrosas aunque exista cifrado.

HTTPS no garantiza que el sitio sea legítimo



https://campus-ejemplo.example

- **El candado indica: la conexión viaja cifrada.**
- **No indica: que este sitio sea el verdadero.**

Cómo comprobar

- Leé el dominio completo
- Escribí la dirección oficial a mano
- Desconfiá de dominios parecidos

Actualizaciones

Corrigen vulnerabilidades conocidas. Activá las automáticas en el sistema, el navegador y las aplicaciones.

CIBERSEGURIDAD E IA

Un mensaje bien escrito también se verifica

Mensaje ficticio

Hola, Damián. Actualizamos los datos de cobro de la factura de este mes. Para evitar demoras, realizá el pago a la nueva cuenta indicada en el archivo adjunto. Gracias por tu colaboración.

Qué evaluar

Identidad del remitente.

Cambio de cuenta solicitado.

Confirmación por un canal ya conocido.

La IA puede ayudar a redactar mensajes convincentes. El estilo por sí solo no confirma su origen.

Verificá el pedido con el contacto habitual antes de cambiar un destino de pago.

CIBERSEGURIDAD E IA

Qué compartimos con una IA

Datos que necesitan resguardo

Contraseñas y claves de API.

Nombres, DNI y datos de contacto de alumnos.

Documentos internos e información confidencial.

Cómo preparar una consulta

Usá ejemplos ficticios y el mínimo de información necesaria.

Revisá herramientas autorizadas, permisos y condiciones de tratamiento de datos.

Ejemplo de consulta

“Explicá este error con un usuario ficticio y una clave de ejemplo”.

CIBERSEGURIDAD E IA

Cómo revisar una respuesta de IA

Respuesta ficticia para analizar

“Para solucionar el problema, desactivá el firewall y volvé a intentar”.

Entender

Qué modifica, con qué permisos y qué riesgo introduce.

Verificar

Contrastá la recomendación con documentación oficial.

Validar

Probá en un entorno de laboratorio y revisá el resultado.

Una respuesta puede parecer segura y contener errores. La revisión sigue siendo necesaria.

Seguridad personal y laboral

En lo personal

- Contraseñas distintas y segundo factor
- Bloquear el celular y la computadora
- Cuidar lo que publicás en redes
- Instalar solo desde tiendas oficiales

En lo laboral

- No compartir credenciales
- Usar solo herramientas aprobadas
- Separar cuentas personales y laborales
- Reportar enseguida cualquier hecho raro

Un descuido personal puede afectar al trabajo, y al revés.

RESPUESTA A INCIDENTES

Qué hacer ante un incidente

01 **Detectar**

Registrar qué ocurrió y cuándo. Una señal aislada requiere evaluación.

02 **Contener y avisar**

Ante sospecha de infección, aislar de la red y contactar a IT según el protocolo.

03 **Proteger las cuentas**

Desde un equipo confiable, revisar accesos, cambiar claves y revocar sesiones si corresponde.

04 **Recuperar y revisar**

El equipo responsable elimina la causa, valida el entorno y restaura datos comprobados.

Conservá evidencias y seguí el protocolo institucional durante la respuesta.

CASO INSTITUCIONAL · 1 DE 3

Una mañana en la secretaría

09:00 — **Llega una factura**

Una persona recibe un correo que parece provenir de un proveedor.

09:10 — **Se abre un adjunto**

Más tarde aparecen archivos inaccesibles y una nota de rescate.

10:00 — **Se interrumpe el trabajo**

Varias computadoras pierden acceso a las planillas compartidas.

Caso ficticio. La secuencia sugiere una hipótesis que debe confirmarse con evidencias.

CASO INSTITUCIONAL · 2 DE 3

Cómo se decide con información incompleta

Lo que sabemos

Hay equipos con archivos inaccesibles.

Existe una nota de rescate.

Una persona abrió un archivo antes de detectar el problema.

Lo que falta averiguar

Qué equipos y cuentas están afectados.

Si las copias siguen disponibles.

Si hubo extracción de datos y cuál fue la vía de entrada.

Primera respuesta coordinada con IT. Aislar equipos afectados y documentar los hechos conocidos.

CASO INSTITUCIONAL · 3 DE 3

De la interrupción a la recuperación

Contención

Separar sistemas afectados y proteger las copias existentes.

Continuidad

Definir qué tareas esenciales pueden continuar por un medio alternativo.

Recuperación

Restaurar en un entorno validado, con copias verificadas y prioridades acordadas.

Aprendizaje

Revisar permisos, actualizaciones, canales de aviso y entrenamiento.

La recuperación incluye comprobar que la causa del incidente quedó resuelta.

SÍNTESIS

Ideas para llevarnos

Mensajes y solicitudes

Verificá identidad, destino y cambios importantes por un canal conocido.

Cuentas

Usá claves únicas, gestor y MFA. Protegé también la recuperación.

Información y dispositivos

Mantené actualizaciones, permisos adecuados y copias verificadas.

IA e incidentes

Resguardá datos, revisá respuestas y reportá señales de compromiso.

Una medida para aplicar esta semana. Elegí una cuenta, un dispositivo o una copia para revisar.

REFERENCIAS · ENLACES CLICABLES

Fuentes para ampliar los temas

OWASP · Password Storage Cheat Sheet
Hashing de contraseñas, salt y parámetros de costo. Abrir fuente

Openwall · John the Ripper
Documentación de la herramienta y modos de auditoría. Abrir fuente

CISA · StopRansomware Guide
Prevención, contención y recuperación de incidentes. Abrir fuente

NCSC · ChatGPT and large language models
Riesgos de compartir información y uso de respuestas. Abrir fuente

FTC · Are Public Wi-Fi Networks Safe?
Alcance del cifrado y sitios fraudulentos. Abrir fuente

CISA · Implementing Phishing-Resistant MFA
Métodos de autenticación resistentes al phishing. Abrir fuente

CLASE 2 · CIBERSEGURIDAD EN LA VIDA REAL

¡Muchas gracias!

¿Preguntas?

Damian Trajster · @damian_dev_web

CFP N.º 20 – AMDELCO

